PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Sécurisation de l'infrastructure VMware

03-330 ANSSI - Sécurisation d'une infrastructure VMware — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. L'infrastructure distingue le plan de contrôle pour le pilotage du plan de donnée pour les machines virtuelles.
2. La connectivité entre un hyperviseur ESXi et les composants comme le vCenter ou la sauvegarde est assurée par l'adaptateur VMKernel.
3. La micro-segmentation via NSX permet de cloisonner les flux est-ouest et nord-sud de manière indépendante du système d'exploitation.

Principes généraux de l'architecture VMware

Notion	À retenir
Hyperviseurs	Cibles privilégiées : compromission = accès à **l'ensemble des données et traitements**. Menaces : **étatique** (espionnage/déstabilisation) ou **cybercriminelle** (lucre/destruction).
Plans de l'infrastructure	Séparation entre **plan de contrôle** (**Management domain**, pilotage) et **plan de donnée** (**Workload domain**, machines virtuelles).
Gestion et connectivité	Privilèges via des **rôles** (privilèges + utilisateur + objet). Connectivité : **vSwitch/dvSwitch**, **vNic** et adaptateurs **VMKernel**.
Micro-segmentation	Via **NSX** (manager, controllers, module kernel ESXi, edges) : limite la latéralisation et les flux **nord-sud/est-ouest**. Hyperviseur > **agent** en VM. **Défense en profondeur**, insuffisante seule.
Vecteurs d'attaque	Cibles de **rançongiciels**. Sources : **latéralisation** (bureautique/sous-traitant), **vulnérabilités**, **binaires compromis**, **absence de MCS**, **implant stockage**, **exposition Internet**.

Recommandations d'architecture VMware

Notion	À retenir
Séparation des flux	Séparer **plan de contrôle** (management vSphere) et **plan de donnée** (machines hébergées). Cloisonner administration, stockage et sauvegarde par **VLAN** et **adaptateurs VMKernel** dédiés.
Clusters et zones	Un cluster **Management domain** dédié héberge le plan de contrôle. Clusters de production dédiés par **zone de sensibilité/confiance** avec **vCenter dédié** par zone.
Socle et annuaires	Socle **critique** avec annuaire d'administration **indépendant** de la production (**Active Directory**). Clusters ESXi et datastores dédiés par **niveau de sensibilité**.

Actions d'administration

Notion	À retenir
Droits et authentification	**RBAC** cohérent avec la délégation, **moindre privilège** (admin et service) ; **MFA** sur vSphere et vCenter ; comptes **dédiés aux API**, connexions supervisées.
MCS des composants	ESXi, **vmware-tools**, vCenter, outils additionnels dans le **MCS** ; désinstaller les outils inutilisés.

Durcissement et supervision

Notion	À retenir
Durcissement ESXi	Désactiver **SSH**, activer **lockdown** (mode normal + **bris de glace**), **secure boot** (vérification **VIB**), **TLS** (vSphere et vMotion), **tagging VLAN** sur l'hyperviseur, pare-feu local et séparation des accès admin.
Supervision sécurité	Archiver/superviser : accès **ESXi**, modifs config, redémarrages, connexions **vSphere/vCenter**, trafic admin (exfiltration), suspensions VM (**dump mémoire**), arrêts massifs (**chiffrement vmdk**), comptes **root** (`vpx-user`, `dcui`), commandes interactives, **guest operations** et transferts **datastores**.

Recommandations NSX et Sauvegarde

Notion	À retenir
Recommandations NSX	Déployer **NSX manager/controllers** sur **cluster d'administration** uniquement. Filtrage sans critère modifiable par la VM (**hostname**, **MAC**). Bloquer tout flux non autorisé. Isolation zones par **pare-feux physiques**.
Sauvegarde	Sauvegarder l'**infrastructure** (binaires, procédures d'import, tests de restauration VM) et les **environnements hébergés** selon le guide **Sauvegarde des systèmes d'information**.

Pièges et confusions

- ⚠ Mutualiser le port d'administration d'une machine virtuelle avec le plan de contrôle du socle
- ⚠ Utiliser une solution de micro-segmentation reposant sur un agent interne à la machine virtuelle plutôt qu'au niveau de l'hyperviseur
- ⚠ Confondre le Management domain (cluster d'administration) avec le Workload domain (cluster de production)
- ⚠ Considérer qu'un vSwitch apporte des fonctions avancées comme les PVLAN contrairement au dvSwitch

Sigles et définitions

Plan de contrôle	Partie de l'infrastructure de virtualisation responsable du pilotage de l'infrastructure virtuelle
Plan de donnée	Partie de l'infrastructure qui porte les machines virtuelles elles-mêmes
Rôle	Ensemble de privilèges spécifiant les actions autorisées et les droits de lecture-écriture sur un objet VMware
dvSwitch	Commutateur de niveau 2 virtualisé apportant une gestion centralisée et des fonctions avancées
Adaptateur VMKernel	Composant portant une adresse IP assurant la connectivité entre un hyperviseur ESXi et les autres composants
Micro-segmentation	Technique de sécurité réseau cloisonnant les flux de chaque VM par des règles granulaires et centralisées
Flux nord-sud	Communications à l'extérieur d'une zone, par exemple vers une passerelle Internet
Flux est-ouest	Communications internes à une zone, par exemple entre serveurs de même sensibilité

Auto-test

1. Quelle est la différence entre un Management domain et un Workload domain ?
2. Quels sont les composants de la solution NSX ?
3. Pourquoi une sécurité au niveau de l'hyperviseur est-elle supérieure à une sécurité par agent ?
4. Que désigne un vSwitch ou dvSwitch ?
5. Quels éléments doivent être déployés sur le cluster d'administration uniquement pour NSX ?

Réponses : **1.** Le Management domain est le cluster d'administration et le Workload domain est un cluster de production · **2.** Le NSX manager, les NSX controllers, un module kernel sur les ESXi et les NSX edges · **3.** Car l'agent est lui-même exposé à une compromission de la VM qu'il est censé protéger · **4.** Un commutateur de niveau 2 virtualisé créé par l'hyperviseur · **5.** Le NSX manager et les NSX controllers

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.